

Enrico Bravi

enrico.bravi@polito.it

Module B – Social Engineering and Digital Identity

B3 – Physical Attacks



**Politecnico
di Torino**

Department of Control and
Computer Engineering



TORSEC

Computer and Network Security Group



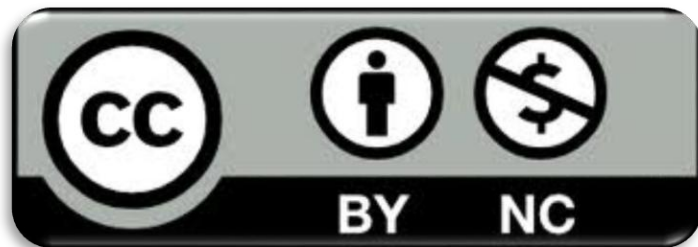
Acknowledgments

This lecture deck *adapts* and *reorganizes* selected teaching material originally developed by Nicolò Maunero (CINI / Cybersecurity National Lab). Portions of the content are reused under the Creative Commons BY-NC license (see license slide). All modifications, additions, re-organization, and any errors are the responsibility of the course instructor.

License & Disclaimer

License Information

This presentation is licensed under the
Creative Commons BY-NC License



To view a copy of the license, visit:

<http://creativecommons.org/licenses/by-nc/3.0/legalcode>

Disclaimer

- We disclaim any warranties or representations as to the accuracy or completeness of this material.
- Materials are provided “as is” without warranty of any kind, either express or implied, including without limitation, warranties of merchantability, fitness for a particular purpose, and non-infringement.
- Under no circumstances shall we be liable for any loss, damage, liability or expense incurred or suffered which is claimed to have resulted from use of this material.
- This material is used and adapted within the course “Cybersecurity and National Defense”.



Learning Goals

- analyzing in detail the so called *Physical attacks*
- proposing possible countermeasures, identified as best practices of the so-called **Cyber Hygiene**



Social Engineering – Attack Vectors

- various types of phishing
- posing as others
- physical attacks
- cognitive type attacks



Social Engineering – Attack Vectors

- various types of phishing
- posing as others
- physical attacks
- cognitive type attacks
- **baiting**
- dumpster diving
- key logging
- piggybacking or shoulder surfing
- physical access



Baiting



- it involves the use of a **bait** to attract the victim

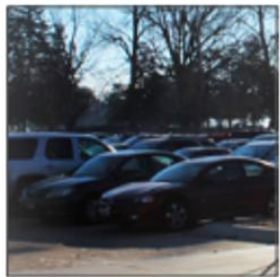


Baiting - Example



USB Pendrives

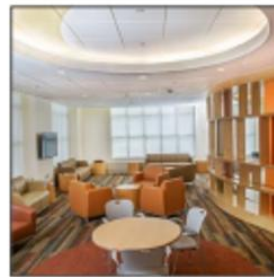
- left by the attacker in a place where it can be taken and used by the victim



Parking lot



Outside



Common room



Classroom



Hallway

Baiting - Example

- not only pendrives, but any device connected to the USB port could infect the PC





Attacks Through USB Devices

- the attacker creates a USB device that, when connected to a computer, simulates a predefined set of commands (**keystrokes**) that can install a malicious program (**payload**) on the computer
- they exploit so-called *Human Interface Device (HID)* or *USB drive-by* attacks

[<https://www.cyberpointllc.com/posts/cp-human-interface-device-attack.html>]

HID Attacks (I)

- an attacker takes:
 - a programmable embedded development platform such as the Teensy 4.0
 - an associated software package such as [Peensy](#) or the [Social Engineering Toolkit \(SET\)](#)





HID Attacks (II)

- then he creates a USB device which when plugged into a computer will execute a **pre-configured** set of **keystrokes** to drop a malicious **payload** onto the target computer
- the actual **payloads** that are dropped and executed are highly configurable and this approach will work on Linux, Windows and Mac OS X



Costs

- the Teensy 4.0 can be purchased for approximately 24 USD
- installing keystrokes and payloads can be very simple due to the highly availability of pre-developed tools online

Google Security Campaign (I)

- the Red Team of Google performed a test to verify the **awareness** of the company employees on Baiting attacks
- the employees were **gifted** with a USB plasma globe
- the globe was loaded with **malicious** software
- When the globe was plugged in it started to send a series of **keystrokes** to the computer that download the payload to allow remote access to the target machines





Google Security Campaign (II)

- this was actually the first link of the **kill chain**
- the target was to **steal** the plans for Google Glass
- some employees got infected (but they were not related with Google Glass) and the attackers were able to use their identity and privilege
- they sent malicious emails (to Google Glass employees) **impersonating** the victims attaching an image (downloaded by a malicious website)
- the website allowed the attackers to retrieve the target's digital fingerprints
- the attackers were able to **authenticate** and download the Google Glass files



Google Security Campaign (III)

- the test ended successfully for the attackers
- 17 Google employees' account were compromised
- 257.9 GB of data was stolen
- mostly important: **0 alarms were raised**

[<https://www.youtube.com/watch?v=TusQWn2TQxQ&t=495s>]



Baiting – Cyber Hygiene

- do not connect anything to the USB port of your PC unless it comes from a reliable and **trusted** source
- access USB sticks that are not yours only through *Virtual Machines* or *Sandboxes*

Baiting Example

- any device you connect to via a USB port could infect your PC or smartphone



Smartphone Charging (I)

- When using a public charge point or the one available in your hotel room, always connect your charger to the electrical outlet: never plug the cable directly into the USB outlet: this could infect your smartphone!





Smartphone Charging (II)

- alternatively, between the cable and the USB socket you can insert a *special device* characterized by connecting only the power pins, leaving those used for data transmission disconnected



Even Charging Can Be Dangerous

Mind The Plug! Laptop-User Recognition Through Power Consumption

Authors:  [Mauro Conti](#),  [Michele Nati](#),  [Enrico Rotundo](#),  [Riccardo Spolaor](#) | [Authors Info & Claims](#)

[IoTPTS '16: Proceedings of the 2nd ACM International Workshop on IoT Privacy, Trust, and Security](#) • Pages 37 - 44
<https://doi.org/10.1145/2899007.2899009>

- in this paper the authors demonstrated that it is possible to infer user behavior (e.g., services used) analyzing the power consumption of a device connected to the electrical network



Social Engineering – Attack Vectors

- various types of phishing
- posing as others
- physical attacks
- cognitive type attacks
- baiting
- dumpster diving
- key logging
- piggybacking or shoulder surfing
- physical access



Dumpster Diving



- it refers to the collection and analysis of scrapped items or materials thrown by the victim



Dumpster Diving - Examples

- an attacker can find a lot of personal data or sensitive company information on:
- dismissed:
 - devices with storage capability (e.g., PCs, external HDD, USB sticks, tablets, smart phones, virtual assistants)
 - paper documents (e.g., diaries, calendars, notebooks)
 - accounts (e.g., e-mail, social, cloud)



The Issue

- unfortunately, unlike what you might think, in a computing system, when you “delete” a file, you don't actually physically delete anything, you simply ask the Operating System to delete that file...or, more precisely, you inform it that you are not going to use that file any longer
- thereafter, the Operating System assumes that the space previously occupied by the deleted file is available and therefore it can “rewrite” it, when needed
- however, the file is still physically stored on the disk and as long as it is not overwritten, it can easily be recovered



Dumpster Diving – Cyber Hygiene

- ALWAYS perform *sanitizing* operations before disposing of any device with memory (smartphones, tablets, PCs, external HD, pendrives, printers, smartTVs, ...)



Sanitizing



- Is the process of removing sensitive data from a system or storage device with the intent that the data cannot be recovered by any known technique

Sanitizing - Approaches

- different solutions (hardware or software) are adopted depending on:
 - security level required
 - type of device to be sanitized
- hardware
 - **degaussing**
- software
 - **wiping**



HDD



SSD



Degaussing



- Is the removal or reduction of a magnetic field of a hard disk or drive, using a device called a *degausser* that has been specifically designed for the media being erased



Degaussing Side Effects

- applied to magnetic media, degaussing may purge an entire media element quickly and effectively
- degaussing often renders hard disks inoperable, as it erases low-level formatting that is only done at the factory during manufacturing
- in some high-security environments, one may be required to use a degausser that has been approved for the task
 - for example, in US government and military jurisdictions, one may be required to use a degausser from the NSA's "Evaluated Products List"



Wiping



- *Wiping*, aka *Overwriting* or *Shredding*, writes new data over each bit or block of file data



Sanitizing – Regulations

- the EU Regulation 2016/679 - GDPR - imposes on organizations:
 - a new **sensitivity** to the problem (penalties are very severe)
 - the implementation of tools that allow to easily manage procedures for secure deletion of data from computers and other devices, in order not to leave traces of **personal** data at the time of reuse of the systems or their disposal (e.g., resale as used, donations, disposal, return at the end of rental/leasing contracts)



Sanitizing – Standards

- several standards have been established regarding procedures to be followed for sanitation, including:
 - *RCMP TSSIT OPS-II*
 - *ISO/IEC 17799*
 - *DoD 5220.22-M, National Industrial Security Program Operating Manual (NISPOM), February 2006*
 - *NIST Special Publication 800-88, Guidelines for Media Sanitization, September 2006*



Sanitizing – Regulations

- In Italy, the [Provvedimento Garante Privacy del 13 ottobre 2008 \(G.U. n.287 del 9.12.2008\)](#), named "*Rifiuti di apparecchiature elettriche ed elettroniche (Raee) e misure di sicurezza dei dati personali*" draws attention to the need to erase personal data from electronic devices intended for reuse, recycling, disposal



Social Engineering – Attack Vectors

- various types of phishing
- posing as others
- physical attacks
- cognitive type attacks
- baiting
- dumpster diving
- key logging
- piggybacking or shoulder surfing
- physical access



Keylogger



- tool capable of intercepting and secretly recording or transmitting everything typed on the keyboard, without the user being aware of it



Keylogger – Possible Implementations

Hardware

- The device is connected either to the communication cable between the keyboard and the computer or inserted inside the keyboard

Software

- A malicious program checks and saves the keystroke sequence that is typed by a user on the keyboard

Hardware Keylogger Example (I)

AirDrive USB Keylogger



AirDrive USB keylogger con 16 MB di capacità, connettività WiFi e personalizzazione della tastiera nazionale. [altro](#)

Prezzo per 1 pz IVA inclusa: **149,00 €**
Prezzo per 1 pz IVA esclusa: 122,13 €

Più di 10 pezzi in magazzino

1

Tempo di spedizione: **entro 24 ore**

Produttore: [KeeLog](#)
Codice prodotto: KL11
Garanzia: 24 mesi



Specialista nel settore **oltre 10 anni**



Hardware Keylogger Example (II)

CARATTERISTICHE PRINCIPALI:

- ▶ registra tutti i tasti premuti da qualsiasi tastiera USB
- ▶ **scarica i dati via WiFi senza bisogno di un contatto fisico con il prodotto**
- ▶ non rilevabile dagli antivirus
- ▶ non influisce in alcun modo sulle prestazioni del computer
- ▶ supporta 40 tipi di tastiere nazionali incluso il ceco
- ▶ connettività con qualsiasi PC, tablet o cellulare

CARATTERISTICHE:

- ▶ attualmente il **più piccolo keylogger sul mercato**, solo 21 mm
- ▶ **16 MB di memoria** - 16.000.000 di battute, cioè circa 8000 pagine di testo
- ▶ funziona come un hotspot WiFi con connessione IP
- ▶ non è richiesto alcun software per connettersi e recuperare i dati
- ▶ Sicurezza WEP, WPA o WPA2
- ▶ Dimensioni: 21 x 19 x 12 mm



Keylogger – Cyber Hygiene

- do not allow cleaning staff access to the sensitive offices when they are unattended



Software Keylogger (I)

➤ *Hypervisor*

malicious hypervisor running below the Operating System, which is not tampered with in any way

➤ *Kernel*

a malicious driver within the Operating System, starting to intercept signals from keystrokes on the keyboard that flow through the kernel

➤ *API*

keyboard APIs within a running application log events from the keyboard, behaving as components of a legitimate application



Software Keylogger (II)

➤ *Form Grabbing*

malware stores information entered into a form on a web page when it is submitted, with the information that is stored before it is sent by the browser



Social Engineering – Attack Vectors

- various types of phishing
- posing as others
- physical attacks
- cognitive type attacks
- baiting
- dumpster diving
- key logging
- piggybacking or shoulder surfing
- physical access

Piggybacking (or Shoulder Surfing)

- ability of an attacker to gain illicit access to a restricted area or information by following at close range someone who does have the authorization and ability to access it



Piggybacking – Cyber Hygiene

- if you find yourself working in crowded places, protect your screens with *Privacy Filters*
- never leave your smartphone or PC unattended: when you walk away, always use the screen **lock**





Social Engineering – Attack Vectors

- various types of phishing
- posing as others
- physical attacks
- cognitive type attacks
- baiting
- dumpster diving
- key logging
- piggybacking or shoulder surfing
- physical access



Physical Access Attacks

- the attacker has physical access to the target system
- physical access bypasses the strongest digital defenses (encryption, firewalls, and 2FA) by attacking the **environment** rather than the **network**
- attackers exploit social norms (politeness, authority, and urgency) to walk through the front door
- once inside, an attacker only needs a few seconds of “hands-on” time to compromise a system permanently

“If a bad actor has unrestricted physical access to your computer, it's not your computer anymore.”



Man-in-the-Video Attacks

What you see is not what you get: a man-in-the-middle attack applied to video channels

Authors:  [Mauro Conti](#),  [Eleonora Losiouk](#),  [Alessandro Visintin](#) | [Authors Info & Claims](#)

[SAC '22: Proceedings of the 37th ACM/SIGAPP Symposium on Applied Computing](#) • Pages 1723 - 1726
<https://doi.org/10.1145/3477314.3507233>

- the authors perform a man-in-the-middle attacks substituting the HDMI cable with a malicious one
- this cable intercepts the video output and manipulates it
 - for example it change the URL showed to the user with a legitim one instead of showing the phishing replica